

Cyber Range Attack Simulation Design Document

C5 — Attacker Piggybacks on EDR Outage

Scenario ID: C5 — Attacker Piggybacks on EDR Outage

Classification: Opportunistic exploitation during security monitoring failure

Document Type: Simulation design specification (consumed by a software development team)

Reference Baseline: MITRE ATT&CK; techniques as listed in the attack flow

Simulation Intent: Visually and behaviourally recreate a coordinated attack during EDR platform failure from both attacker and defender vantage points. This is a software simulation. It contains no exploit code, no malware, and no weaponisable detail — only the observable behaviour, telemetry, and state changes a development team needs to model.

Design North Star: Every stage must be expressible as a state transition with associated attacker output, victim experience, SOC-visible telemetry, and defender decision options. If a stage cannot be reduced to those four lenses, it is under-specified.

3. Attacker Journey (Action Sequence) — Red Team Journey

Unlike WannaCry's automated worm, this simulation features human-operated ransomware with deliberate exploitation of degraded visibility. The sequence below represents coordinated threat actor actions.

#	Attacker Action	Trigger	Target	Result
1	Monitor OSINT for EDR outage reports	EDR vendor update failure	Global organizations	Target list compiled
2	Launch password spray attacks	Outage confirmed	External auth portals	Valid credentials obtained
3	Establish VPN/RDP access	Credentials acquired	Corporate network	Initial foothold achieved
4	Deploy custom tooling	Access established	Compromised endpoint	Persistence established
5	Perform AD reconnaissance	Foothold secured	Domain environment	Privilege targets identified
6	Harvest credentials via LSASS	Local admin obtained	Memory/registry	Domain credentials acquired
7	Execute lateral movement	Privileged access	Adjacent systems	Network spread achieved
8	Enumerate sensitive data	Multi-system access	File shares/databases	Critical data located
9	Stage data for exfiltration	Data discovered	Temp locations	Data ready for theft

10	Exfiltrate to cloud storage	Staging complete	External destination	Data theft completed
11	Delete shadow copies	Pre-encryption prep	All systems	Recovery disabled
12	Deploy ransomware	Recovery disabled	Enterprise-wide	Mass encryption initiated
13	Drop ransom notes	Encryption complete	All endpoints	Extortion demand presented
14	Leak data samples	Payment refused	Public sites	Pressure amplified

***Crucial modelling property:** Unlike automated malware, these are deliberate, sequenced actions by human operators who adapt based on defender responses and leverage the EDR blindness window.*

4. Victim Journey (Per-Host Experience)

What infected endpoints and their users experience during the attack:

- 1. EDR failure notification** — Security teams alert users that endpoint protection is degraded.
- 2. Normal operations continue** — Users work unaware of active compromise.
- 3. Subtle performance impact** — Minor slowdowns from attacker reconnaissance.
- 4. Unusual authentication prompts** — Credential harvesting attempts.
- 5. Network drive slowdowns** — Data staging operations impact performance.
- 6. Sudden file unavailability** — Ransomware encryption begins.
- 7. Desktop wallpaper change** — Ransom note appears.
- 8. Complete system lockout** — All files encrypted, business operations halted.

State progression: Protected → Vulnerable → Compromised → Infiltrated → Exfiltrating → Encrypted → Ransomed

5. SOC Analyst Journey (What's Visible, When)

With EDR telemetry lost, analysts must rely on alternative data sources with varying effectiveness:

Stage	What lands in the SIEM/console	Signal strength	Typical analyst reaction
EDR Outage	Agent heartbeat failures, service crashes	High/Obvious	Vendor escalation initiated
Password Spray	Failed auth spike in Azure/AD logs	Medium	Often missed in noise
Initial Access	VPN connections from unusual locations	Low-Medium	May flag for review
Persistence	Windows Event Log service/task creation	Very Low	Rarely collected centrally
Credential Dump	Nothing (EDR would catch)	None	Completely blind
Lateral Movement	Unusual RDP/SMB in netflow	Low	Requires correlation
Data Discovery	File server audit logs (if enabled)	Very Low	Usually not monitored
Exfiltration	Large outbound HTTPS to cloud services	Medium	May trigger DLP
Shadow Deletion	Nothing without EDR	None	Critical signal lost
Encryption	File audit events, backup failures	High	Too late to prevent
Ransom Notes	Help desk tickets surge	Critical	Incident declared

Key SOC training insight: The most critical detection opportunities (credential dumping, shadow deletion) are completely invisible without EDR, while network-based signals are weak and easily missed.

6. Blue Team Journey (Defender Actions Available)

For each stage, defenders have limited options due to visibility loss:

Stage reached	Detect	Investigate	Contain	Eradicate
EDR Outage	Monitor agent health	Check vendor status	Enable audit logging	Deploy alternate tools
Password Spray	Review auth logs	Correlate failures	Force MFA	Reset passwords
Initial Access	VPN anomaly detection	Verify user activity	Disable accounts	Revoke sessions
Persistence	Limited visibility	Manual system checks	Network isolation	Reimage systems
Credential Dump	Not detectable	Memory analysis	Rotate all credentials	Domain reset
Lateral Movement	Netflow analysis	Track connections	Segment networks	Disable protocols
Data Discovery	File audit review	Identify accessed data	Revoke permissions	Audit shares
Exfiltration	Proxy log analysis	Quantify data loss	Block destinations	Legal action

Shadow Deletion	Not detectable	Verify backup status	Protect backups	Offline backups
Encryption	Mass file changes	Assess damage	Full isolation	Restore from backup

Highest-leverage defender moves:

- **Immediate network segmentation** when EDR fails
- **Emergency MFA enforcement** on all accounts
- **Offline backup isolation** before encryption
- **Alternative monitoring deployment** (Sysmon, network sensors)

7. Detailed Stage Breakdown

Stage 1 — Outage Identification (T1592)

Objective: Identify exploitable visibility gap

Inputs: Public reports, social media, vendor advisories

Actions: OSINT gathering, target enumeration, infrastructure prep

Outputs: Prioritised target list with confirmed EDR outages

State changes: External → Targeting

Telemetry: None (external reconnaissance)

Detection opportunities: Threat intel on actor infrastructure

Visual representation: World map with affected organisations highlighted

Network changes: None

Business impact: None yet

Stage 2 — Credential Attack (T1110)

Objective: Obtain valid authentication credentials

Inputs: Username lists, common passwords, breach databases

Actions: Password spray against cloud services, VPN, webmail

Outputs: Valid credential pairs

State changes: Targeting → Credentialed

Telemetry: Failed authentication events, account lockouts

Detection opportunities: Auth anomaly detection, impossible travel

Visual representation: Authentication timeline showing spray pattern

Network changes: Minimal (external to auth endpoints)

Business impact: None visible

Stage 3 — Initial Access (T1078)

Objective: Establish network presence

Inputs: Valid credentials

Actions: VPN authentication, RDP connection, cloud service access

Outputs: Network access achieved

State changes: Credentialed → Compromised

Telemetry: Successful VPN/RDP logs, new session creation

Detection opportunities: Unusual access location/time

Visual representation: Network edge showing entry point

Network changes: New VPN tunnel established

Business impact: None apparent

Stage 4 — Payload Deployment (T1055)

Objective: Establish persistent control

Inputs: Initial access

Actions: Deploy Cobalt Strike, create scheduled tasks, install services

Outputs: C2 channel established

State changes: Compromised → Persistent

Telemetry: Process creation (if logged), network connections to C2

Detection opportunities: Network anomalies, DNS beaconing

Visual representation: Host showing implant installation

Network changes: Periodic C2 callbacks

Business impact: None visible

Stage 5 — Persistence Establishment (T1053)

Objective: Survive reboots and maintain access

Inputs: Local/admin access

Actions: Scheduled tasks, WMI subscriptions, service creation

Outputs: Multiple persistence mechanisms

State changes: Persistent → Entrenched

Telemetry: Windows Event Log entries (if centralised)

Detection opportunities: Extremely limited without EDR

Visual representation: Timeline showing persistence points

Network changes: None

Business impact: None visible

Stage 6 — Defence Evasion (T1562)

Objective: Avoid detection

Inputs: System access

Actions: Disable logging, clear event logs, use legitimate tools

Outputs: Reduced detection surface

State changes: Visible → Stealthy

Telemetry: Event log clearing (if noticed)

Detection opportunities: Log gaps, service stops

Visual representation: Visibility gauge dropping

Network changes: None

Business impact: Security posture degraded

Stage 7 — Credential Dumping (T1003)

Objective: Escalate privileges

Inputs: Local admin access

Actions: LSASS dumping, SAM extraction, DCSync

Outputs: Domain admin credentials

State changes: User-level → Domain Admin

Telemetry: None without EDR

Detection opportunities: Completely blind

Visual representation: Privilege escalation graph

Network changes: DCSync traffic (subtle)

Business impact: Total compromise achieved

Stage 8 — Network Discovery (T1018)

Objective: Map environment

Inputs: Domain access

Actions: AD queries, share enumeration, network scanning

Outputs: Complete infrastructure map

State changes: Blind → Omniscient

Telemetry: LDAP queries, SMB enumeration

Detection opportunities: Unusual AD query patterns

Visual representation: Network topology being revealed

Network changes: Increased internal scanning

Business impact: None visible

Stage 9 — Lateral Movement (T1021)

Objective: Spread across environment

Inputs: Admin credentials, target list

Actions: RDP, PSEXEC, WMI, PowerShell Remoting

Outputs: Multi-system compromise

State changes: Single → Widespread

Telemetry: RDP/SMB connections in netflow

Detection opportunities: Unusual admin tool usage patterns

Visual representation: Infection spreading across network

Network changes: East-west traffic increase

Business impact: Multiple systems compromised

Stage 10 — Data Collection (T1074)

Objective: Identify valuable data

Inputs: File system access

Actions: Automated searches, database dumps, email collection

Outputs: Sensitive data identified and staged

State changes: Searching → Collecting

Telemetry: File access logs (if enabled)

Detection opportunities: Mass file access patterns

Visual representation: Data flowing to staging points

Network changes: Internal transfer spikes

Business impact: Data breach imminent

Stage 11 — Data Exfiltration (T1567)

Objective: Steal sensitive information

Inputs: Staged data

Actions: Compression, encryption, upload to cloud storage

Outputs: Successful data theft

State changes: Staged → Exfiltrated

Telemetry: Large outbound HTTPS transfers

Detection opportunities: DLP alerts, unusual cloud uploads

Visual representation: Data leaving network boundary

Network changes: Sustained outbound transfers

Business impact: Intellectual property stolen

Stage 12 — Disable Recovery (T1490)

Objective: Prevent restoration

Inputs: Admin access

Actions: Delete shadow copies, corrupt backups, disable recovery

Outputs: Recovery options eliminated

State changes: Recoverable → Unrecoverable

Telemetry: None without EDR

Detection opportunities: Backup system alerts

Visual representation: Recovery options disappearing

Network changes: Backup system modifications

Business impact: Recovery complexity maximised

Stage 13 — Ransomware Deployment (T1486)

Objective: Encrypt all systems

Inputs: Domain admin, ransomware payload

Actions: GPO deployment, scheduled task execution, PSEXEC distribution

Outputs: Mass encryption

State changes: Operational → Encrypted

Telemetry: Mass file modifications, CPU/disk spike

Detection opportunities: Too late — damage done

Visual representation: Systems turning red simultaneously

Network changes: Minimal (encryption is local)

Business impact: Complete operational failure

Stage 14 — Business Impact (T1657)

Objective: Maximise pressure for payment

Inputs: Encrypted environment

Actions: Leak data samples, public announcements, ransom negotiations

Outputs: Reputational damage, operational crisis

State changes: Crisis → Catastrophe

Telemetry: External reporting, media coverage

Detection opportunities: N/A (post-incident)

Visual representation: News feeds, stock price impact

Network changes: None

Business impact: Quantified in Section 11

8. EDR Outage Model

Visibility Loss Simulation

Lost Capabilities:

- Process creation/injection monitoring
- File system activity tracking
- Registry modification detection
- Memory integrity validation
- Behavioural analysis
- Automated threat blocking
- Forensic data collection
- Real-time alerting

Remaining Capabilities:

- Network flow data (if collected)
- Firewall logs
- Proxy/web gateway logs
- Authentication logs
- Some Windows Event Logs
- Email gateway logs
- Cloud service logs
- Physical security logs

Degradation Timeline:

T+0min: EDR update pushed globally
T+5min: Kernel crashes begin
T+15min: 50% endpoints offline
T+30min: 90% endpoints offline
T+2hr: Vendor acknowledges issue
T+6hr: Workaround published
T+12hr: 30% systems recovered
T+24hr: 70% systems recovered
T+48hr: Full recovery

Attacker Advantage Window: 6–48 hours of severely degraded visibility

9. Data Exfiltration Model

Collection Methodology:

- Automated discovery using findstr/PowerShell
- Targeting: financial data, PII, intellectual property, credentials
- Staging in %TEMP% and public folders

- Compression using 7-zip/rar with encryption
- Cloud upload via HTTPS to avoid detection

Exfiltration Indicators (Limited Without EDR):

- Large outbound HTTPS sessions to cloud storage
- Unusual times for data transfers
- New cloud storage domains in proxy logs
- Sustained upload traffic patterns
- User accounts accessing unusual data volumes

Business Impact:

- Customer records stolen: 2M+ records
- Financial data compromised: 5 years of records
- Intellectual property theft: Core product designs
- Credentials harvested: All domain users
- Compliance violations: GDPR, CCPA, HIPAA
- Estimated loss: \$50M–\$100M

10. Ransomware Deployment Model

Pre-Encryption Actions:

- Identify critical systems (DC, Exchange, SQL, file servers)
- Map backup infrastructure
- Disable VSS across domain via GPO
- Stop backup services
- Delete System Restore points
- Corrupt online backups

Encryption Strategy:

- Use domain admin for mass deployment
- Prioritise servers over workstations
- Target specific file extensions
- Employ intermittent encryption for speed
- Skip system files to maintain botnet

Impact Cascade:

Hour 0: Encryption begins

Hour 1: File servers locked

Hour 2: Database servers encrypted

Hour 3: Email systems offline

Hour 4: Backup systems corrupted

Hour 6: Manufacturing halted

Hour 8: Complete business stoppage

Ransom Mechanics:

Parameter	Detail
Initial demand	\$10M in Bitcoin
Escalation	+\$1M per day
Leak threat	100GB data per week
Negotiation	Via Tor chat
Payment deadline	7 days
Decryption	No guarantee

11. Business Impact Model

Immediate Costs (Week 1):

- Incident response: \$2M
- Forensics investigation: \$1M
- Legal consultation: \$500K

- Crisis communications: \$500K
- Ransom payment (if paid): \$10M+
- Emergency IT resources: \$1M

Recovery Costs (Months 1–3):

- System rebuilding: \$5M
- Data restoration: \$3M
- Security improvements: \$10M
- Business continuity: \$2M
- Compliance remediation: \$5M

Long-term Impact (Year 1):

- Lost revenue: \$50M
- Customer churn: 20%
- Regulatory fines: \$20M
- Legal settlements: \$30M
- Insurance premium increase: 200%
- Market value loss: \$200M

Operational Metrics:

- Systems encrypted: 85%
- Data exfiltrated: 500GB
- Recovery time: 4–6 weeks
- Employees impacted: 100%
- Customers affected: 2M+

12. Decision Points

Critical Decision Matrix:

DP	Timing	Decision Required	Correct Action	Wrong Action	Impact of Inaction
DP 1	EDR Failure	Response strategy	Deploy alternative monitoring	Wait for vendor fix	12-hour blind window
DP 2	Auth Anomalies	Account security	Global password reset + MFA	Selective response	Initial compromise
DP 3	Suspicious VPN	Access control	Disable remote access	Monitor only	Foothold established
DP 4	C2 Detection	Network response	Full network isolation	Selective blocking	Lateral movement
DP 5	Data Transfer	Exfiltration response	Internet kill switch	Monitor/log	Data theft complete
DP 6	Backup Alarms	Recovery protection	Offline backup isolation	Trust online backups	Recovery impossible
DP 7	Encryption Start	Containment	Network segmentation	Endpoint isolation	Mass encryption
DP 8	Ransom Demand	Payment decision	Refuse and rebuild	Pay ransom	No guarantee of recovery
DP 9	Data Leak Threat	Public response	Transparent disclosure	Denial/delay	Regulatory penalties
DP 10	Recovery Strategy	Restoration approach	Clean rebuild	Quick restore	Reinfection risk

Decision Consequences:

Optimal Path (Early Action) — DP1→DP2→DP3: Prevent initial compromise

- Cost: \$5M
- Downtime: <24 hours
- Data loss: None

Suboptimal Path (Delayed Action) — Miss DP1–3, catch at DP4–5: Limit damage

- Cost: \$20M
- Downtime: 1 week
- Data loss: Some exfiltration

Worst Path (Late Action) — Miss DP1–5, react at DP6+: Full impact

- Cost: \$100M+
- Downtime: 4+ weeks
- Data loss: Complete

13. State Machine

System State Transitions:

[*] --> Protected: Normal Operations
Protected --> Degraded: EDR Failure
Degraded --> Targeted: Reconnaissance
Targeted --> Probed: Password Spray
Probed --> Breached: Valid Credentials
Breached --> Compromised: Initial Access
Compromised --> Persistent: Implant Deployed
Persistent --> Privileged: Credentials Dumped
Privileged --> Spreading: Lateral Movement
Spreading --> Collecting: Data Discovery
Collecting --> Exfiltrating: Data Theft
Exfiltrating --> Encrypting: Ransomware Launch
Encrypting --> Ransomed: Business Halted

Degraded --> Hardened: Quick Response
Hardened --> Protected: Recovery
Ransomed --> Negotiating: Ransom Discussion
Negotiating --> Recovering: Payment/Rebuild
Recovering --> Protected: Full Restoration

Actor State Machine:

[*] --> Reconnaissance
Reconnaissance --> Targeting: Victims Identified
Targeting --> Attacking: Credentials Targeted
Attacking --> Established: Access Gained
Established --> Escalating: Privileges Gained
Escalating --> Operating: Domain Controlled
Operating --> Exfiltrating: Data Located
Exfiltrating --> Impacting: Ransomware Ready
Impacting --> Extorting: Ransom Demanded
Extorting --> [*]: Mission Complete

Attacking --> Blocked: Detected Early
Blocked --> [*]: Attack Failed
Operating --> Contained: Detected Late
Contained --> Impacting: Partial Success

14. Simulation Timeline — Hour-by-Hour Progression

Day 0 — The Outage

Time	Event
00:00	EDR vendor pushes faulty update
00:15	First crashes reported globally
00:30	Mass sensor failures cascade
01:00	SOC realises scope of outage
02:00	Attackers begin reconnaissance
04:00	Target selection complete
06:00	Password spraying begins
12:00	First successful authentication
16:00	Initial implants deployed
20:00	Persistence established

Day 1 — The Infiltration

Time	Event
08:00	Privilege escalation begins
10:00	Domain credentials obtained
12:00	Lateral movement initiated
16:00	20 systems compromised
20:00	Data discovery automated
23:00	Sensitive data located

Day 2 — The Collection

Time	Event
02:00	Data staging begins
08:00	100GB staged for exfiltration
12:00	Exfiltration to cloud storage
18:00	200GB successfully exfiltrated
22:00	Backup systems identified

Day 3 — The Preparation

Time	Event
------	-------

01:00	Backup corruption initiated
04:00	Shadow copies deleted
08:00	Recovery options disabled
14:00	Ransomware staged
18:00	Final exfiltration
22:00	Ready for encryption

Day 4 — The Attack

Time	Event
03:00	Ransomware deployment via GPO
03:30	Domain controllers encrypted
04:00	File servers encrypting
05:00	Database servers locked
06:00	First employees arrive to chaos
07:00	Help desk overwhelmed
08:00	Crisis team activated
09:00	Business operations halted
12:00	Public disclosure required
18:00	Ransom negotiations begin

Critical Timeline Branches:

Best Case (Immediate Response):

- T+1hr: Alternative monitoring deployed
- T+6hr: Attack detected and blocked
- T+12hr: Full recovery
- Impact: Minimal

Realistic Case (Delayed Response):

- T+12hr: Partial detection
- T+24hr: Some systems protected
- T+72hr: Partial encryption
- T+1wk: Recovery complete
- Impact: Significant

Worst Case (No Response):

- T+96hr: Full compromise
- T+120hr: Complete encryption
- T+1mo: Partial recovery
- Impact: Catastrophic

15. Final Scenario Blueprint

Core Simulation Architecture — Environment Configuration:

- 1,000 endpoints (Windows 10/11)
- 100 servers (mixed Windows Server versions)
- 10 domain controllers
- 20 network segments
- Cloud services (O365, Azure)
- EDR platform (failed state)
- SIEM (partially functional)
- Backup infrastructure

Actor Entities:

```
red_team:
type: human_operated
sophistication: high
objectives: [data_theft, ransomware]
ttp_set: fin7_similar
```

```
blue_team:
visibility: severely_degraded
tools: [siem, netflow, logs]
staff: [soc_l1, soc_l2, ir_team]
```

```
business:
criticality: high
data_sensitivity: pii_financial
recovery_capability: limited
```

Simulation Execution Flow:

```
class EDROutageSimulation:
def initialize(self):
self.trigger_edr_failure()
self.degrade_visibility()
self.alert_attackers()

def attack_phase_1(self): # Exploitation
self.reconnaissance()
self.credential_attacks()
self.initial_access()
self.establish_persistence()

def attack_phase_2(self): # Expansion
self.privilege_escalation()
self.lateral_movement()
self.network_discovery()

def attack_phase_3(self): # Collection
```

```

self.data_discovery()
self.data_staging()
self.data_exfiltration()

def attack_phase_4(self): # Impact
self.disable_recovery()
self.deploy_ransomware()
self.demand_ransom()

def defender_responses(self):
self.decision_points()
self.containment_actions()
self.recovery_operations()

```

Victory Conditions:

Role	Victory Conditions
Red Team Victory	>500GB data exfiltrated • >80% systems encrypted • Ransom payment received • Attribution avoided
Blue Team Victory	Attack detected <6 hours • <10% systems impacted • No data exfiltrated • Full attribution achieved
Draw Conditions	Partial encryption (40–60%) • Some data loss (<100GB) • Extended downtime (1–2 weeks) • Ransom not paid

Scoring Rubric:

Metric	Weight	Measurement
Detection Speed	30%	Hours to first true positive
Containment Effectiveness	25%	% systems protected
Data Loss Prevention	20%	GB exfiltrated
Recovery Time	15%	Hours to restoration
Cost Minimisation	10%	Total incident cost

Learning Objectives:

EDR Dependency Recognition

- Understand critical capability gaps
- Identify alternative detection methods
- Appreciate defence-in-depth value

Incident Response Under Pressure

- Make decisions with limited visibility
- Prioritise actions without full context
- Balance speed vs accuracy

Business Impact Understanding

- Recognise cascade effects
- Quantify decision consequences

- Communicate with leadership

Alternative Detection Methods

- Network flow analysis
- Authentication anomalies
- Behavioural patterns without EDR

Crisis Management

- Multi-team coordination
- External communication
- Ransom negotiation considerations

Implementation Requirements:

Category	Components
Technical	Attack simulation engine • Network topology simulator • Telemetry generation system • Decision tree processor • Scoring algorithm • Visualisation renderer
Data	EDR failure patterns • Attack behaviour models • Network traffic templates • Business impact calculations • Decision outcome matrices
Interface	SOC analyst console • IR command centre • Executive dashboard • Network visualisation • Timeline viewer • Decision point interface

Safety Controls:

Explicit Non-Goals:

- No real malware execution
- No actual network scanning
- No genuine exploitation
- No real data theft
- No actual encryption

Simulation Boundaries:

- All events are simulated state changes
- Telemetry is generated, not captured
- Decisions affect simulation state only
- No external network connections
- No real system modifications

This blueprint provides a comprehensive, implementation-ready design for a sophisticated cyber range simulation that accurately represents the challenges of responding to a coordinated attack during a critical security tool outage. The scenario teaches critical lessons about resilience, alternative detection methods, and crisis decision-making under severely degraded visibility conditions.